GRC103 — Social Engineering and Phishing Campaign Simulation

Week 3 Practical Lab Report

Student Name: Imelda Sanya
Registration Number:C11/26/CGRCE/17576

1. Executive Summary

I set up a phishing-awareness exercise in Kali Linux using GoPhish and Mailpit. I wanted to see how the tools work together and review the events recorded when a test recipient interacts with a simulation email. I used one fictional test account and a simple acknowledgement form. No real employees, external mailboxes or credentials were involved.

The campaign had one fictional recipient. GoPhish recorded the email as sent, followed by a link click and a form submission. The only value captured was training_acknowledgement=acknowledged. Password capture was disabled. The dashboard shows one email open, but the recipient timeline does not list an open event. I have reported the dashboard figure with that difference clearly noted.

The test message appeared in Mailpit, and the recipient record shows a link click and form submission. Since this was a one-person test using a fictional account, the results cannot tell us how likely employees in a real organisation are to fall for phishing.

2. Scope and Methodology

2.1 Objective

The purpose was to set up and run a safe phishing simulation, review the events recorded by GoPhish, and identify areas an organisation could consider when reviewing security awareness and phishing reporting.

2.2 Environment and components

- Operating environment: Kali Linux Rolling 2026.2 (x86_64) running in a local virtual machine.
- Phishing simulation platform: GoPhish, with its administration interface accessed locally at 127.0.0.1:3333.
- Email capture: Mailpit v1.33.0, with its web interface at 127.0.0.1:8025 and SMTP listener at 127.0.0.1:1025.
- Test recipient: lab.user@example.invalid, a fictional address in a single-recipient group named GRC Lab Test Group.
- Campaign: GRC Lab Phishing Simulation, using the GRC Security Awareness Test email template and GRC Security Awareness Training Portal landing page.

2.3 Safety controls

Mailpit's SMTP service and web interface were configured for local use. The campaign used a fictional recipient, and the landing page contained an acknowledgement form rather than a login form. Submitted-data capture was enabled for the acknowledgement; password capture was disabled.

2.4 Method

1. Verify that GoPhish was available and that Mailpit was listening on the local interfaces.
2. Configure the GoPhish sending profile to use the local Mailpit SMTP service and confirm delivery with a test email.
3. Create the fictional recipient group, email template, and training landing page.
4. Configure and launch the campaign using the local landing-page URL.
5. Review the Mailpit inbox and the GoPhish campaign dashboard and individual recipient timeline.
6. Record the submitted form field and calculate the observed event rates using the single targeted recipient as the denominator.

3. Campaign Results and Analysis

GoPhish shows that the campaign was created on 3 November 2026 at 2:42:38 a.m. The recipient timeline records the email sent at 3:00:07 a.m., the link clicked at 3:04:17 a.m., and the acknowledgement submitted at 3:05:04 a.m.

Metric	Observed count	Rate	Interpretation
Targeted recipients	1	—	One fictional test recipient.
Email sent (GoPhish)	1	100%	GoPhish recorded one email sent.
Email captured in Mailpit	1	100%	The campaign message was visible in the local capture inbox; this is not proof of external delivery.
Email opened (dashboard)	1	100%	Aggregate dashboard count; no corresponding open event appears in the individual timeline.
Link clicked	1	100%	The recipient timeline records a click event.
Submitted data	1	100%	The form submission contained only a benign acknowledgement value.
Email reported	0	0%	No report event was recorded by this lab campaign.

3.1 Event timing

- Email sent: 3:00:07 a.m.
- Link clicked: 3:04:17 a.m. (approximately 4 minutes 10 seconds after sending).
- Data submitted: 3:05:04 a.m. (approximately 47 seconds after the click and 4 minutes 57 seconds after sending).

3.2 Submitted data

The GoPhish submission details show one parameter: training_acknowledgement with the value acknowledged. This is a training acknowledgement, not a credential. The landing-page configuration had Capture Submitted Data enabled and Capture Passwords disabled.

3.3 Interpretation of the open metric

The results page shows one email open. However, the individual timeline lists the campaign creation, email sent, link clicked and data submitted events, but no separate open event. I have therefore treated the open figure as a dashboard result only. The click and submission are also visible in the recipient-level record.

4. Phishing Risk Assessment

Observed condition	Potential risk	Evidence from this exercise	GRC consideration
A test recipient followed	A user may be persuaded	One click event recorded.	Reinforce link-verification

the simulated link.	to follow an unexpected link.		habits and provide a clear way to report suspicious messages.
A test recipient submitted the form.	A convincing request may prompt users to provide information.	One acknowledgement submission; no credentials collected.	Train users to verify requests before entering information and distinguish legitimate internal forms.
No report event was recorded.	Suspicious messages may not be escalated through the reporting process.	Email Reported = 0 in the dashboard.	Make reporting instructions easy to find and ensure staff know the approved reporting route.
Dashboard and recipient timeline differ on the open event.	Over-reliance on a single aggregate metric may lead to inaccurate conclusions.	Dashboard shows one open; individual timeline has no open event.	Validate event-level evidence before using metrics in management reporting.

I have not assigned an organisation-wide risk rating from this exercise. It involved one fictional recipient in a local lab and did not test real users, business systems or production controls.

5. Recommendations

7. **Strengthen phishing awareness.** Provide short, recurring awareness sessions covering unexpected links, urgent requests, sender verification, and safe handling of attachments.
8. **Promote a simple reporting route.** Clearly communicate the approved method for reporting suspicious emails and reinforce that reporting is encouraged.
9. **Use safe simulation practices.** Continue using authorised, scoped simulations with test accounts or approved participants. Avoid collecting real passwords or sensitive personal data.
10. **Review event evidence before reporting.** Compare campaign-level metrics with individual event records and document any discrepancies, especially where metrics are used for management decisions.
11. **Improve landing-page feedback.** Consider displaying a clear completion message after the acknowledgement form is submitted so the user receives confirmation that the exercise step is complete.
12. **Expand future testing only with approval.** If a broader assessment is required, define an approved participant population, communications plan, success criteria, privacy safeguards, and reporting process before running the exercise.

6. Limitations

- Only one fictional test recipient was included; the results are not statistically representative of an employee population.
- Mailpit captured email locally. The exercise did not test delivery through an external mail provider or an organisation’s production email security gateway.
- No production identity, endpoint, network, or access-control systems were assessed.
- The exercise did not test the effectiveness of organisational MFA, email filtering, security-awareness programmes, or incident-reporting channels.
- The absence of an Email Reported event in this campaign does not establish that an organisation lacks a reporting capability.

- The aggregate dashboard's open count was not corroborated by the individual recipient timeline.

7. Conclusion

This exercise gave me practical experience setting up GoPhish, connecting it to Mailpit and running a phishing-awareness campaign in a controlled environment. The campaign recorded a link click and an acknowledgement submission without collecting passwords or personal information. It also showed why the campaign summary should be checked against the individual event records. These results describe this lab run only; they do not measure an organisation's overall ability to resist phishing.

Appendix A. Evidence Screenshots

The following screenshots document the configuration, execution, and observed results of the local lab. They are presented in workflow order.

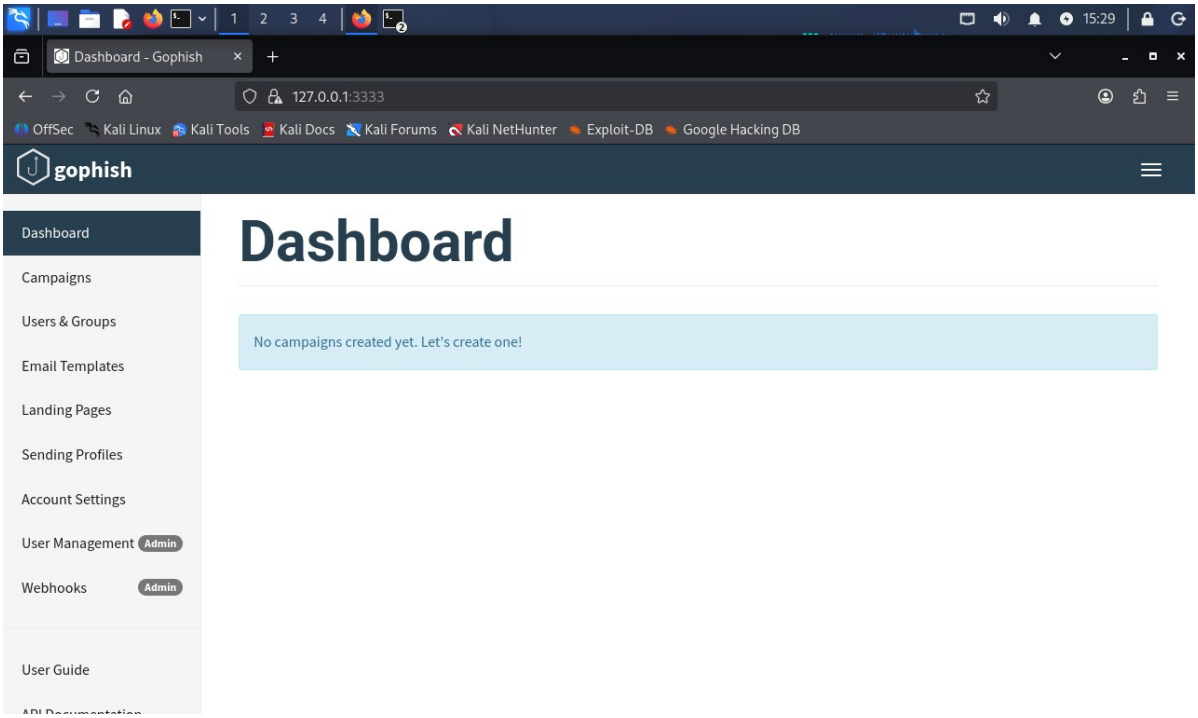


Figure 1. GoPhish dashboard before campaign creation.

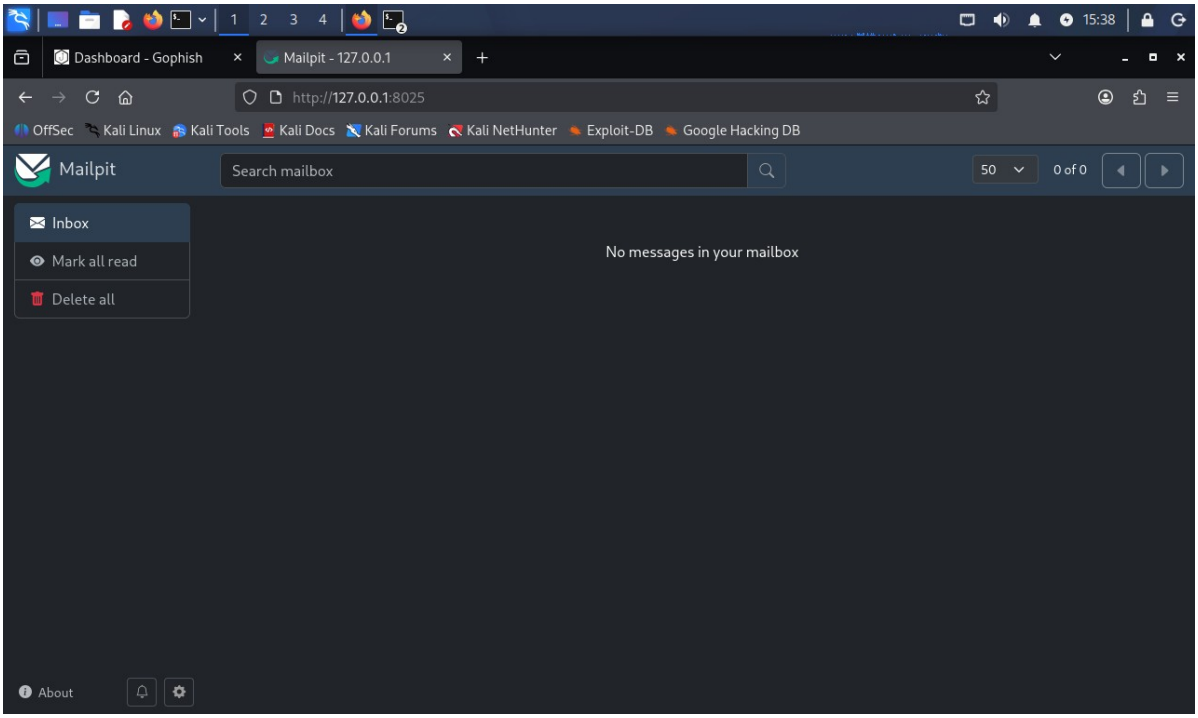


Figure 2. Mailpit inbox before the campaign email was received.

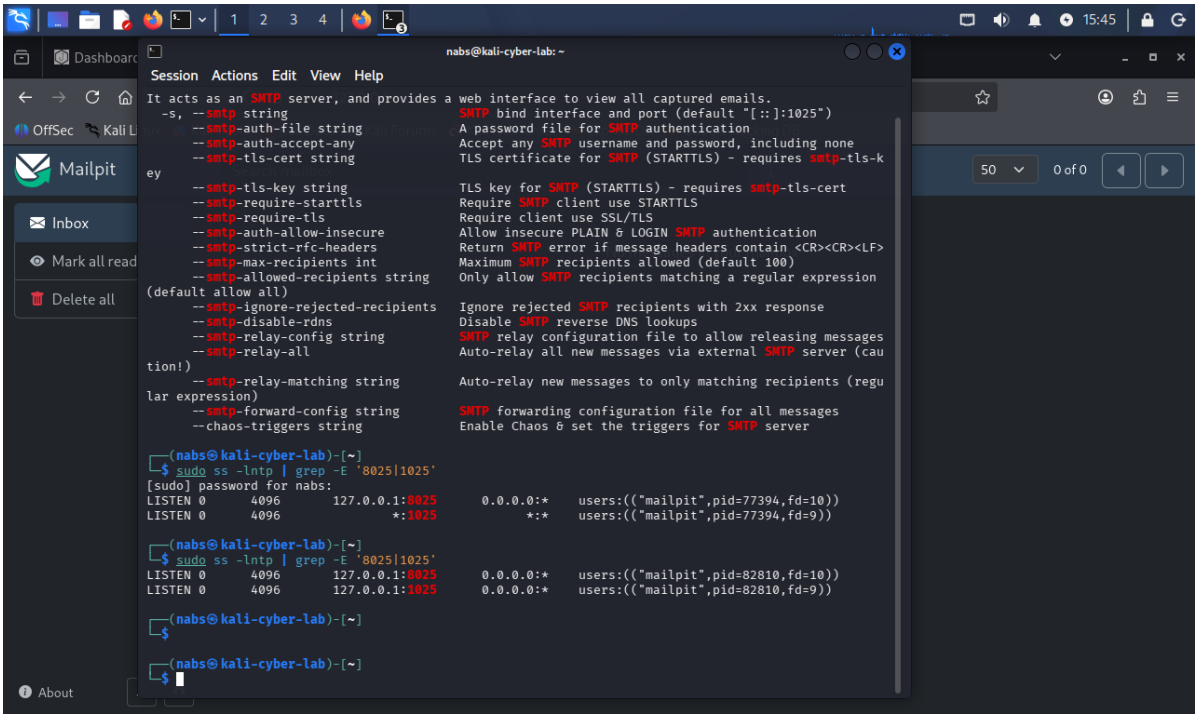


Figure 3. Mailpit SMTP and web interface bound to localhost (127.0.0.1).

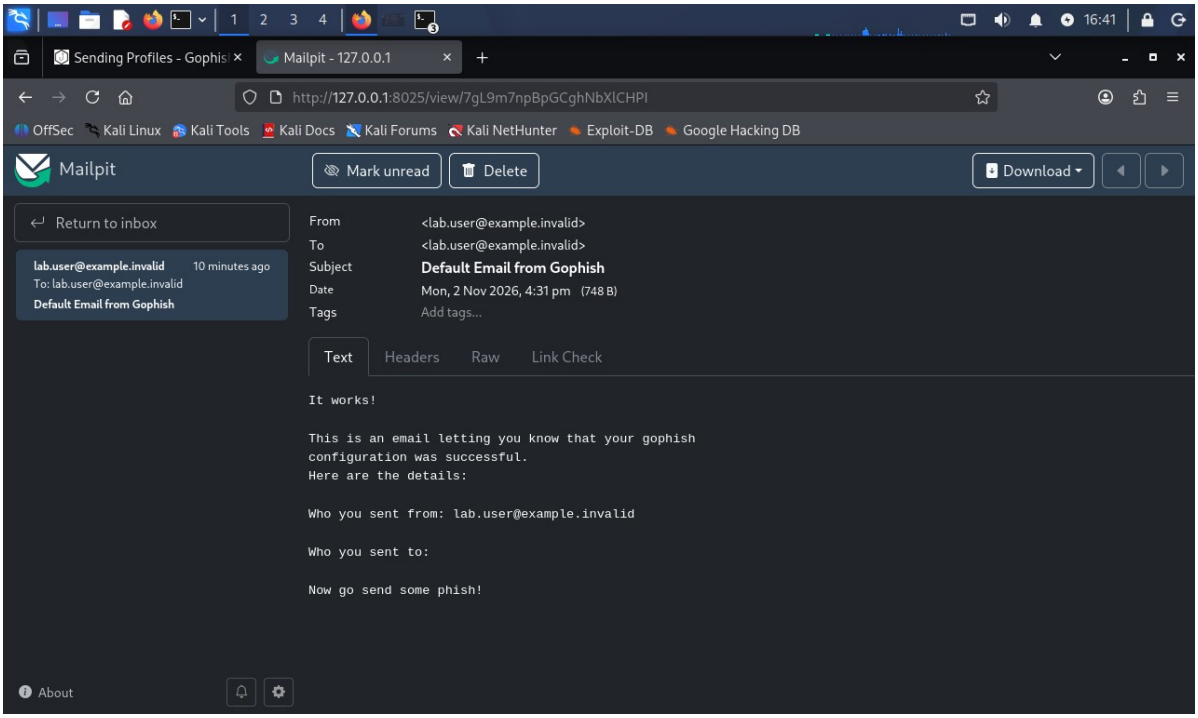


Figure 4. Successful GoPhish test email captured by Mailpit.

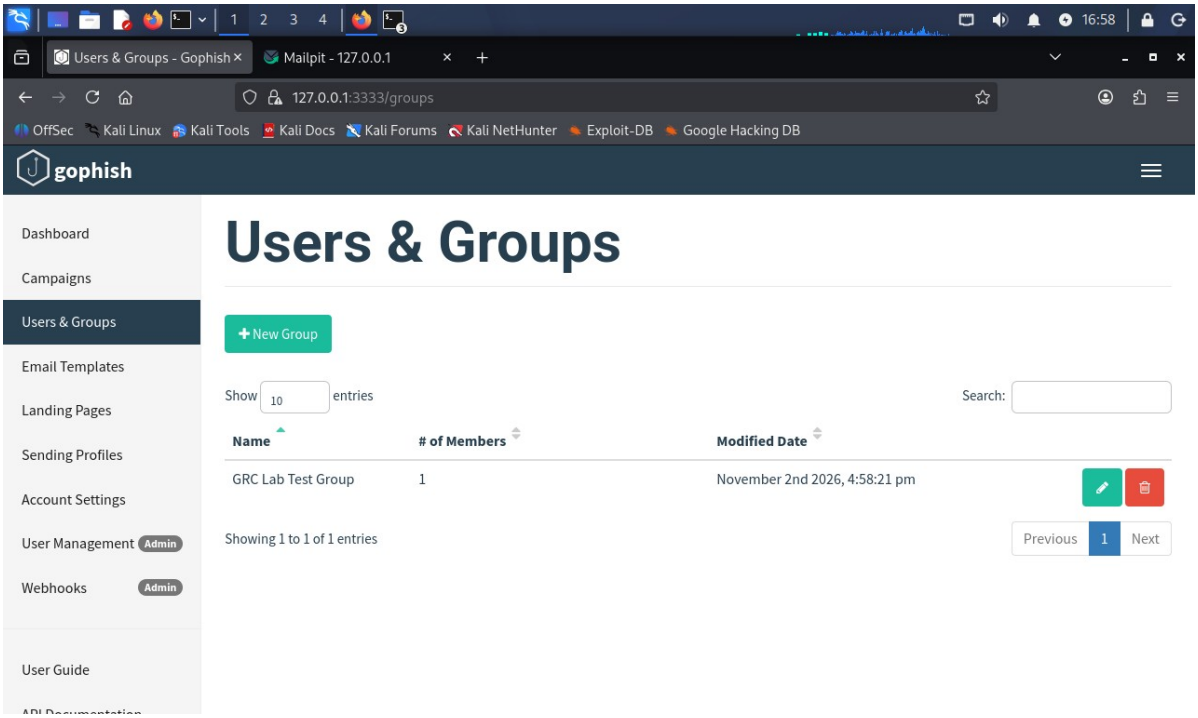


Figure 5. Fictional GRC Lab Test Group configured with one test recipient.

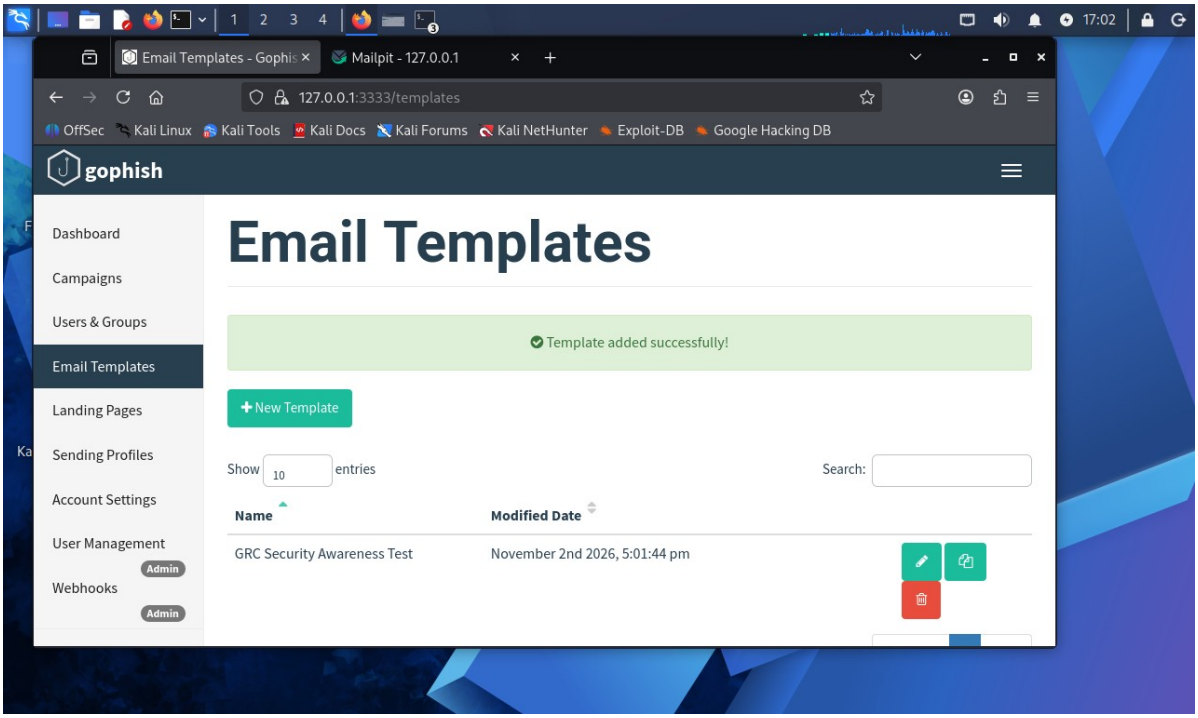


Figure 6. GRC Security Awareness Test email template created in GoPhish.

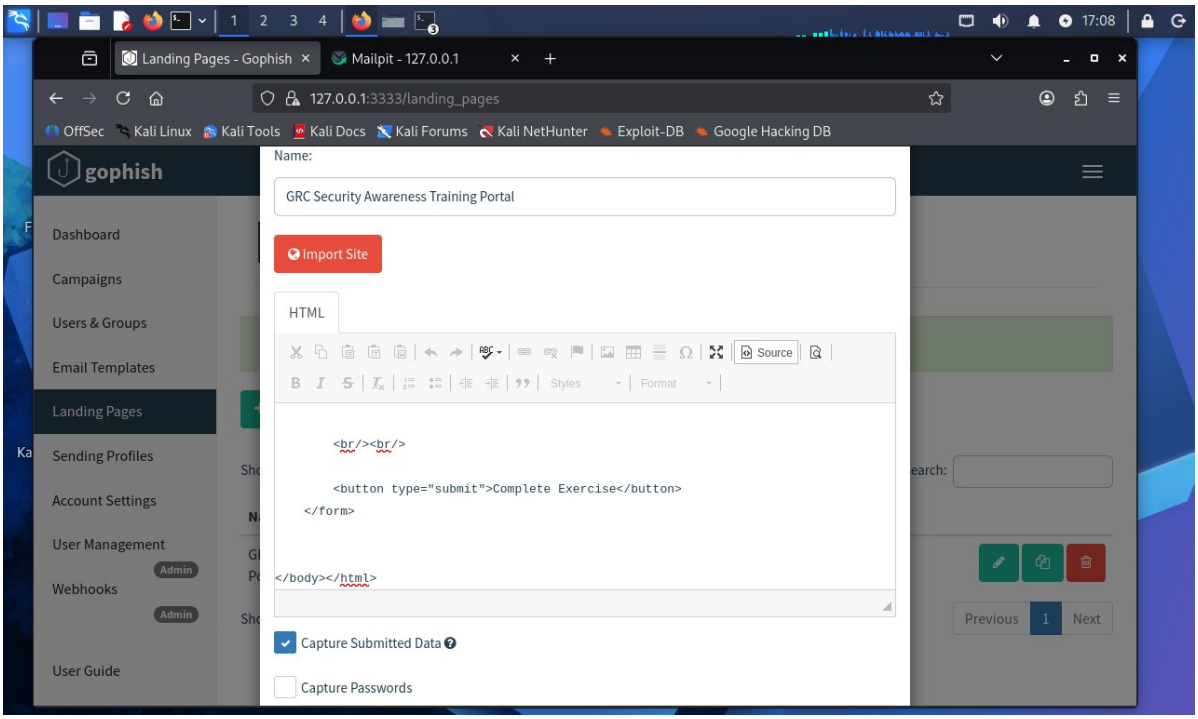


Figure 7. Training landing page configuration, with submitted-data capture enabled and password capture disabled.

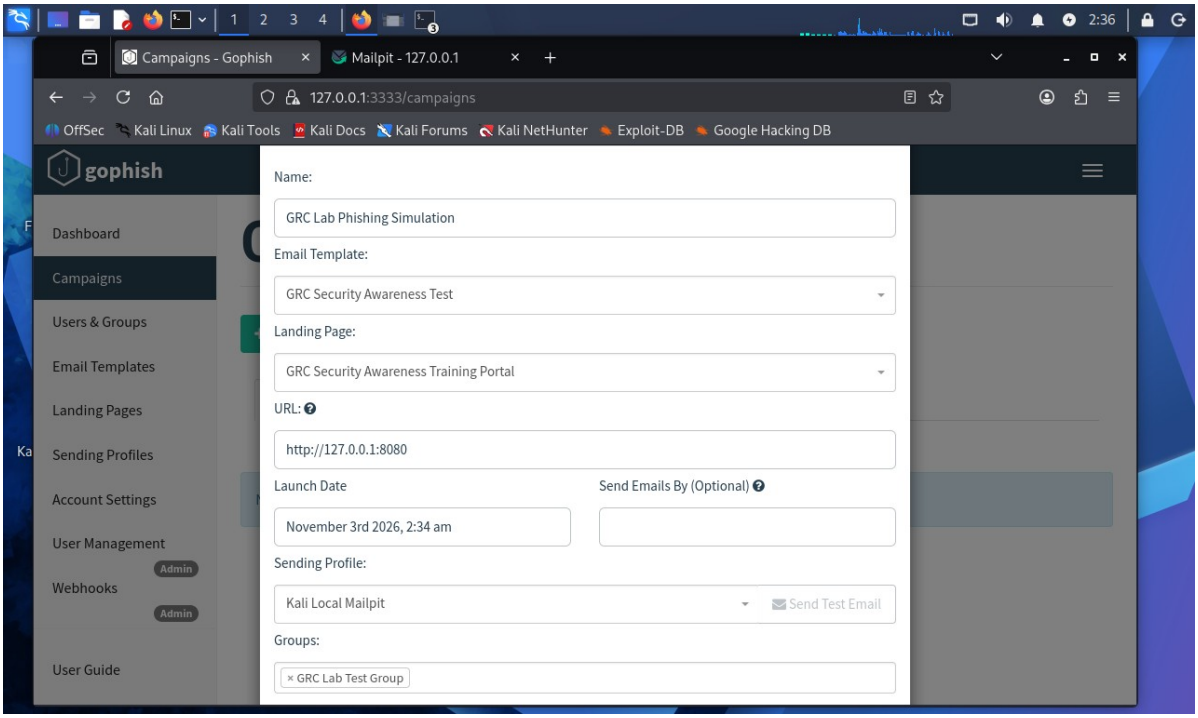


Figure 8. GRC Lab Phishing Simulation campaign configuration.

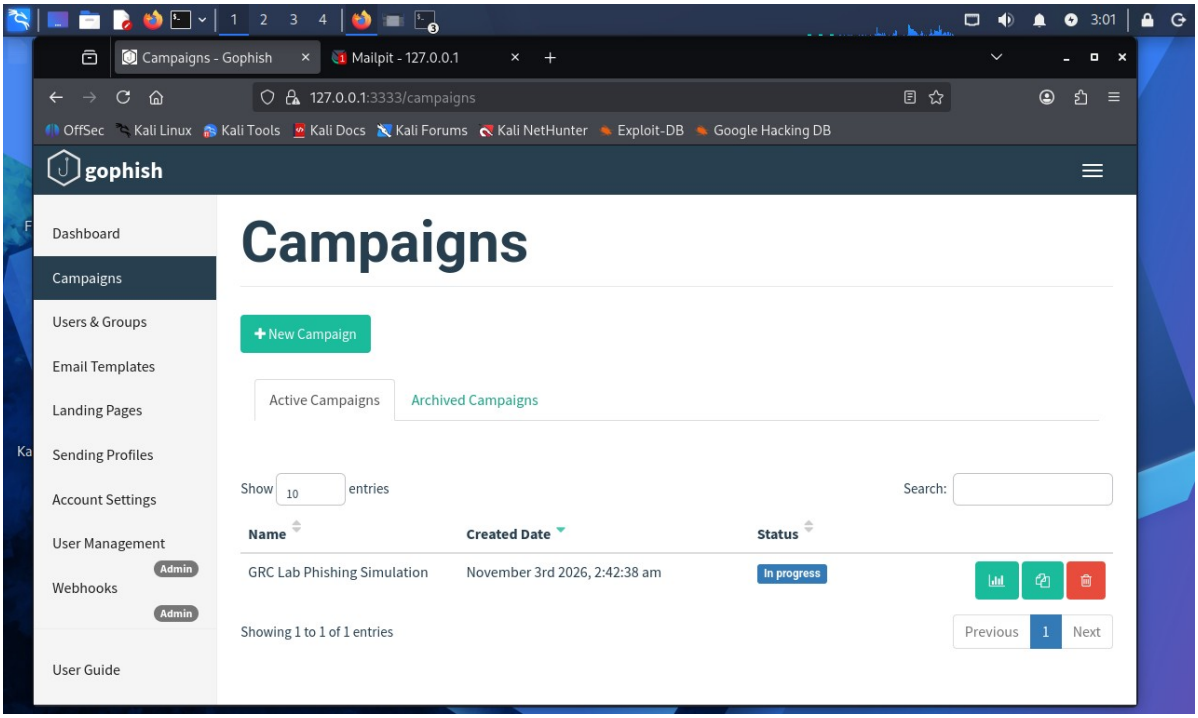


Figure 9. Campaign listed in GoPhish with status In progress.

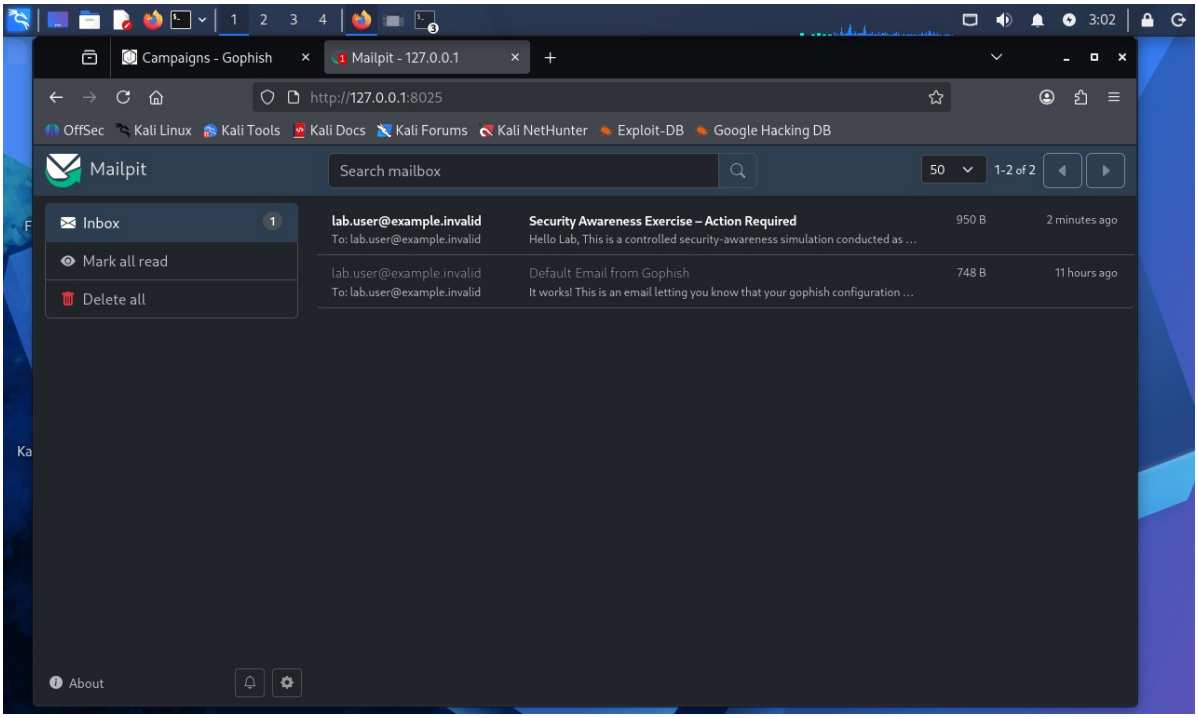


Figure 10. Campaign email captured in the local Mailpit inbox.

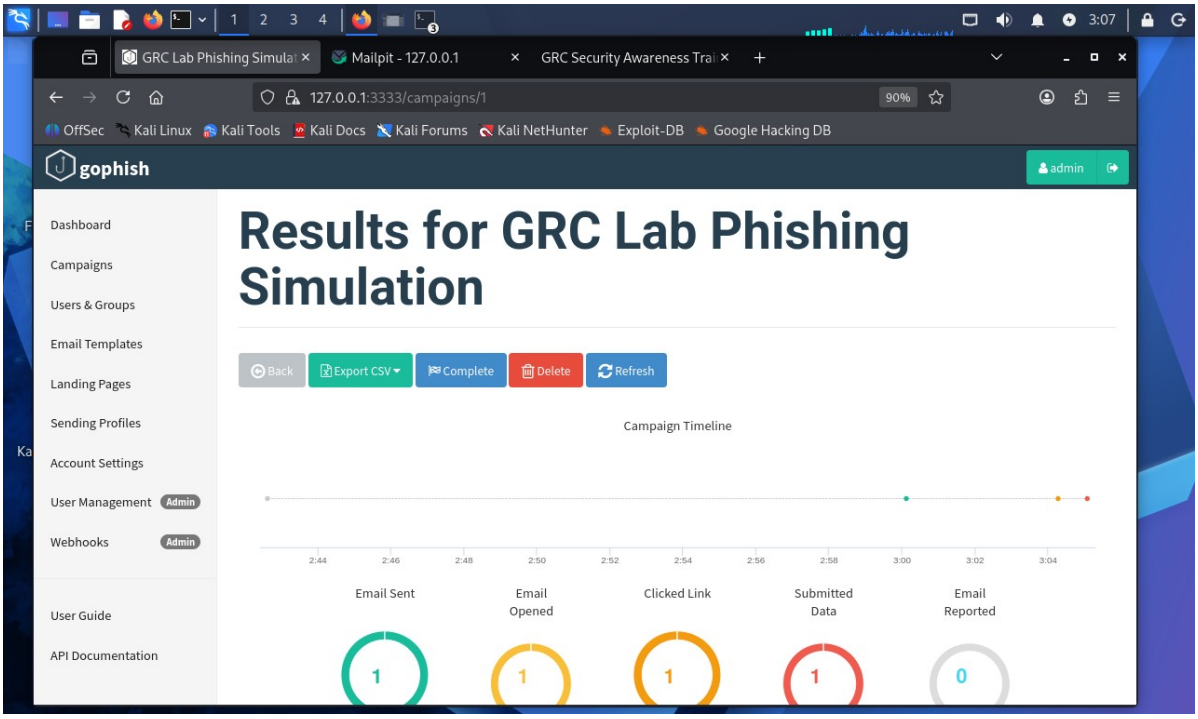


Figure 11. GoPhish campaign results dashboard.

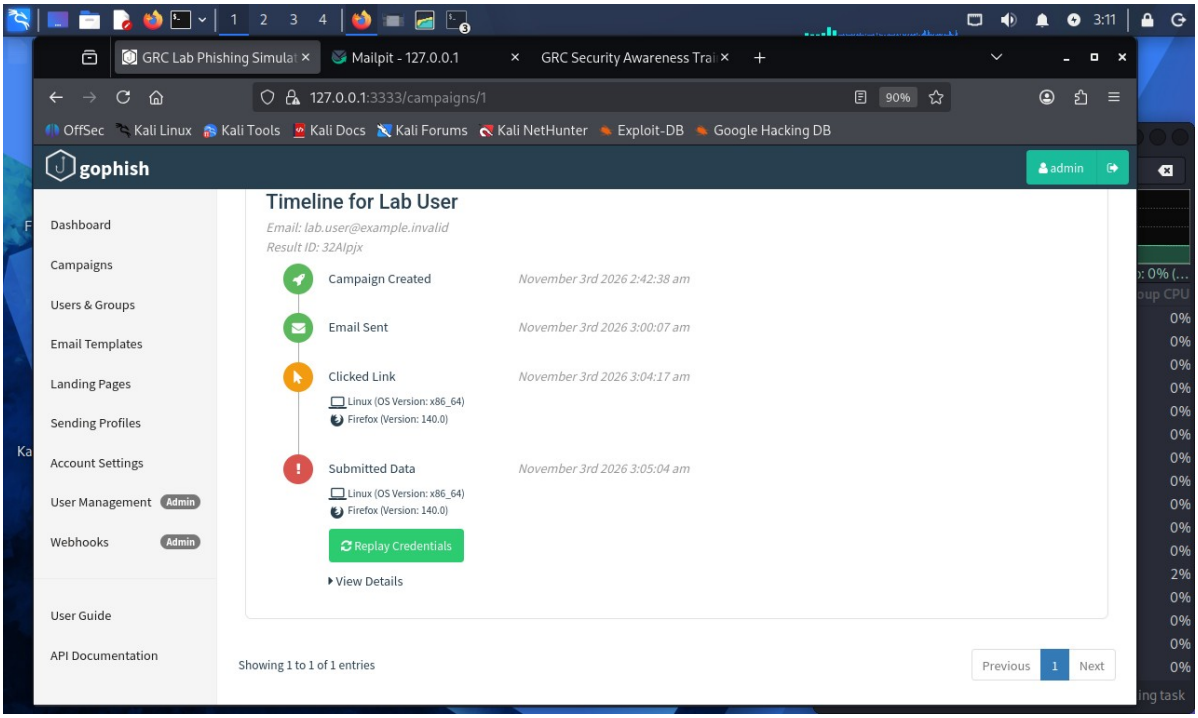


Figure 12. Individual recipient event timeline showing email sent, link clicked, and data submitted.

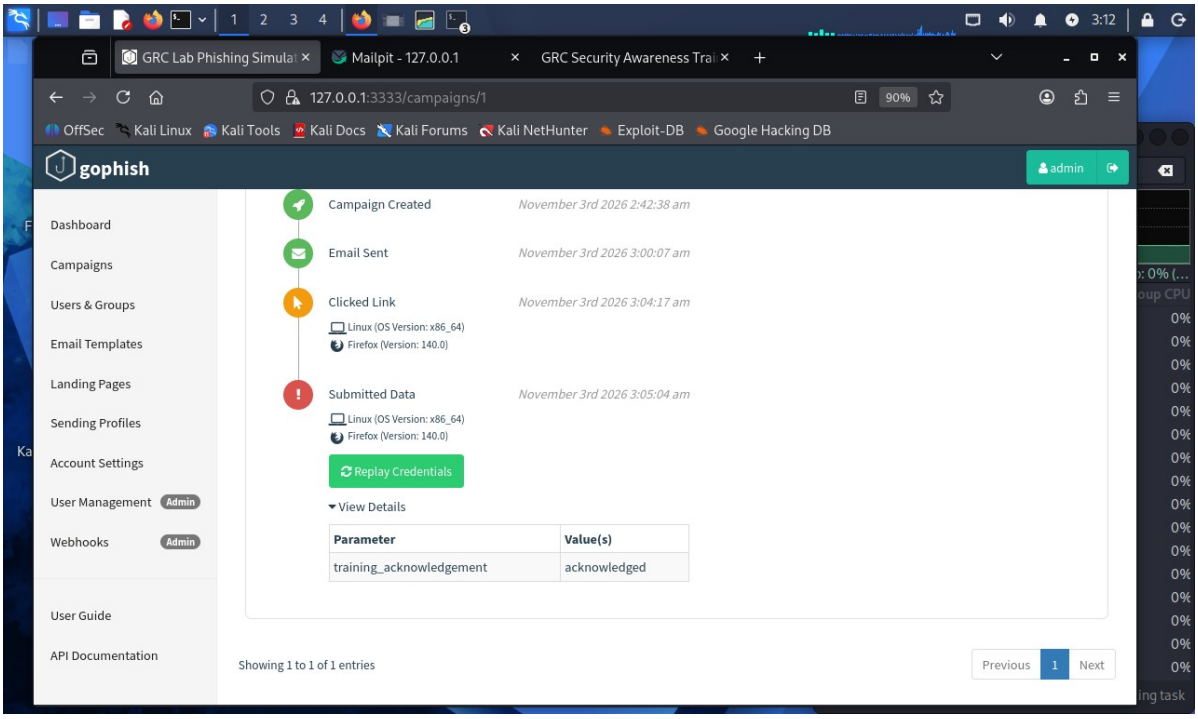


Figure 13. Submitted form data showing only training_acknowledgement=acknowledged.

Appendix B. Calculation Summary

All percentage calculations use the one targeted recipient as the denominator. Rate = observed event count ÷ 1 targeted recipient × 100.

Measure	Calculation	Result

Email sent rate	1 ÷ 1 × 100	100%
Mailpit capture rate	1 ÷ 1 × 100	100%
Dashboard open rate	1 ÷ 1 × 100	100% (qualified by timeline discrepancy)
Click rate	1 ÷ 1 × 100	100%
Submitted-data rate	1 ÷ 1 × 100	100%
Email reported rate	0 ÷ 1 × 100	0%

Note: These rates describe this single-recipient lab run only. Mailpit capture rate refers to local message capture, not delivery to an external mailbox.